

Übung Cybersicherheit

Übungsblatt 9: DoS, DNS, CSS, SQL-Injection

Christian Niesler

Fakultät für Informatik

Arbeitsgruppe Systemsicherheit <https://www.syssec.wiwi.uni-due.de/>

Universität Duisburg-Essen

a) Beschreiben Sie die drei Typen von XSS Angriffen: Reflected XSS, Stored XSS und DOM-Based XSS.

Stored XSS:

- XSS-Attacken die permanent auf dem Server gespeichert werden zum Beispiel in einer Datenbank (Nachrichtenforum, Besucherlog, Kommentarfeld)
- Das Opfer erhält den böswilligen Code direkt vom Server, sobald Informationen vom Server angefragt werden

Reflected XSS

- Bei reflected XSS wird der böswillige Code vom Server aufs Opfer reflektiert
 - Dies kann z.B. durch eine Fehlermeldung erfolgen
- In den Fällen wo die Webseite auf Basis von Client kontrollierten Input eine Antwort erzeugt
- Reflected Angriffe dem Opfer z.B. durch einen manipulierten Link ausgeliefert

DOM XSS oder Client-Side XSS

- Bei DOM XSS wird die lokale Dom Struktur auf dem Client modifiziert bzw der client-seitige Code verändert
- Der böswillige Code wird nicht mit der Serverantwort ausgeliefert, aber der client-seitige Code verhält sich aufgrund lokaler Änderungen der Umgebung anders

Aufgabe 1

b) Um XSS zu vermeiden empfiehlt es sich jegliche Benutzereingaben zu filtern ('Sanitization'). Eine weitere Maßnahme zur Vermeidung von XSS ist CSP (Content Security Policy). Beschreiben Sie die Funktion sowie die Vor- und Nachteile von CSP.

- Es gibt einen HTTP CSP Header, welcher mit ausgeliefert werden kann.
- Dieser spezifiziert, welche Dateien (bzw. welchen Ursprungs) geladen werden dürfen.

Vorteile:

- erschwert XSS-Angriffe

Nachteile:

- erschwert lokales debugging

Aufgabe 1

c) Beschreiben Sie wie SQL-Injection funktioniert und wie Sie eine Anfrage formulieren würden, um die Loginmaske einer Webseite zu umgehen und auf den Account administrator zuzugreifen, von der Sie wissen, dass die Passwörter mit SQL-Query in Listing 1 überprüft werden. Sie können dabei die Parameter \$username und \$password über das Formular frei eingeben.

Aufgrund fehlender „Sanitization“ können SQL Befehle über Parameter wie username oder password injiziert werden

SQL-Query als Batched statement:

Select uid From users Where username = "test" and password = "test"; Select * From users Where username = "administrator!"

\$password ist dann: "test";

Select * From users Where username = "administrator"

Aufgabe 1

d) Beschreiben Sie sowohl abstrakt als auch konkret, wie Sie den Query aus der vorhergehenden Teilaufgabe (Listing 1) verändern müssen, um SQL-Injection zu verhindern. Sie können sich bei der konkreten Beschreibung eine gängige Programmiersprache für das Web (z.B. PHP) aussuchen.

Sonderzeichen wie das genutzte ';' maskieren!

Bsp: `$escaped_password = mysql_real_escape_string($password);`

Aufgabe 2: Denial of Service

a) Was ist das (technische) Ziel eines DoS-Angriffs?

Ausgesuchte IT-Systeme koordiniert mit einer großen Last spezieller Anfragen durch Erschöpfung der verfügbaren Ressourcen lahmzulegen.
Normale Anfragen können nicht mehr bedient werden.

Beispiele für Ressourcen:

- CPU (Rechenleistung)
- RAM (Speicher)
- Bandbreite

Aufgabe 2: Denial of Service

*b) Benennen Sie die CIA-Ziele.
Welche dieser Ziele werden bei einem DoS-Angriff-verletzt?*

Die CIA-Ziele:

Confidentiality (Vertraulichkeit) 

Integrity (Integrität) 

Availability (Verfügbarkeit) 

DoS-Angriffe betreffen nur die Verfügbarkeit.

Aufgabe 2: Denial of Service

c) Benennen und beschreiben Sie unterschiedliche Angriffstechniken für die Durchführung von DoS-Angriffen.

Single Client

Ein einzelner Client erzeugt viele Anfragen.

Amplification

Andere Protokolle werden benutzt, um die Menge und Größe von Anfragen zu erhöhen.

Botnetze

Malware auf Clients schickt koordiniert Anfragen.

Aufgabe 2: Denial of Service

d) Worin unterscheiden sich DoS und DDoS-Angriffe? Warum sind letztere schwieriger abzuwehren?

DoS: Denial of Service

Kann auch von einem einzelnen Client ausgehen.

DDoS: Distributed Denial of Service

Viele unterschiedliche Anfragequellen. Verteilt und Heterogen.

Schwer von richtigen Anfragen zu unterscheiden.

Wenig Möglichkeiten Quelle auf Netzebene zu identifizieren/blockieren.

Aufgabe 2: Denial of Service

e) Was ist das Konzept hinter ‚Amplification‘-Angriffen?

Bei Amplification und Reflection-Angriffen werden andere Protokolle benutzt um die Menge und Größe von Anfragen zu erhöhen, z.B.

- NTP
- DNS
- SNMP

Benutzt IP-Spoofing (Fälschen der Absenderadresse, um Antwort auf Victim zu leiten)

Typischerweise Protokolle die kleine UDP-Anfragen mit großen Paketen beantworten

Aufgabe 3: Botnetze

a) Nennen Sie drei bekannte Botnetze.

Zeus

Mirai

Ziel: IoT-Geräte

Conficker

Bredolab

Aufgabe 3: Botnetze

b) Beschreiben Sie zwei Möglichkeiten, wie ein neues System Teil eines Botnetzes werden kann.

Malware, z.B. via Mail

Exploits, also das Ausnutzen von Sicherheitslücken

Manuelle Installation, z.B. auf Servern

Aufgabe 3: Botnetze

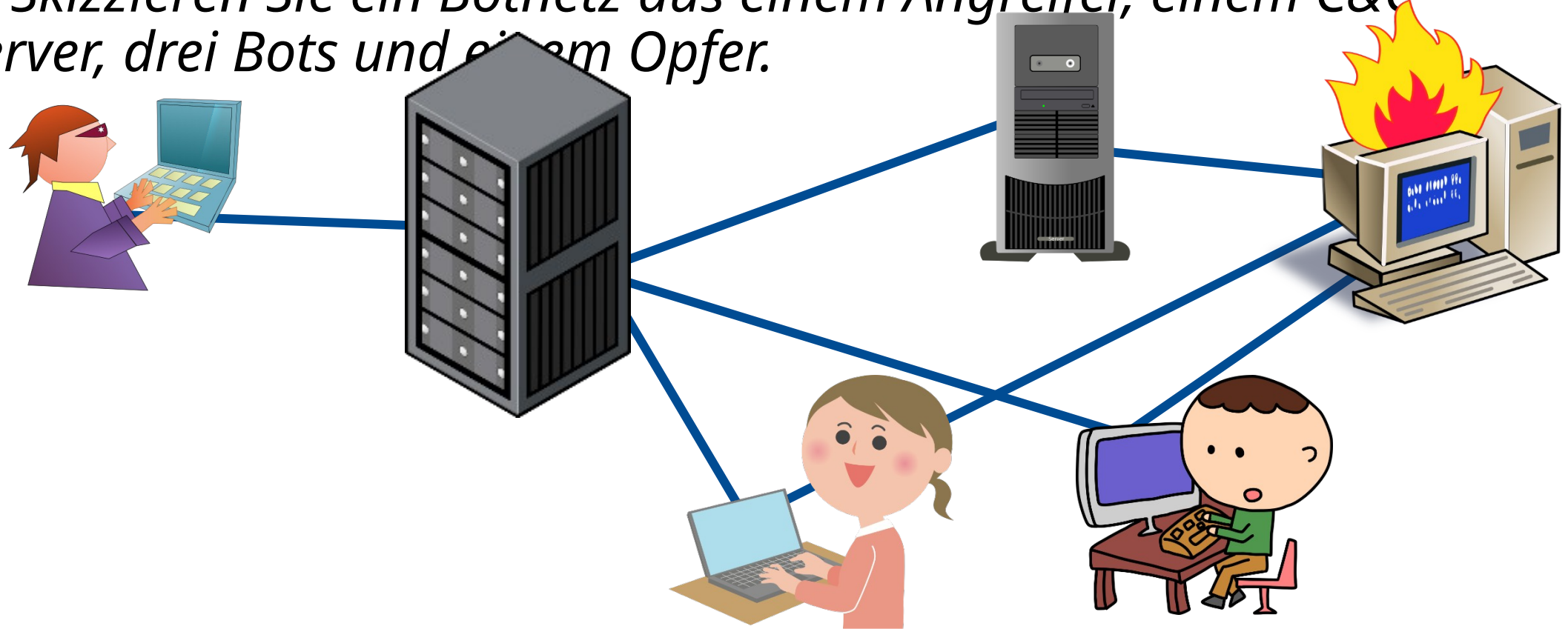
c) Was ist ein Command&Control Server?

Ein Command&Control Server steuert die Kommunikation zwischen dem Angreifer und dem Botnetz. Aufgaben sind das Verteilen neuer Anweisungen und das Übertragen von Daten. Als Protokoll wird häufig IRC, HTTP oder DNS verwendet.

Alternativ können Botnetze auch als P2P Netzwerk organisiert werden.

Aufgabe 3: Botnetze

d) Skizzieren Sie ein Botnetz aus einem Angreifer, einem C&C Server, drei Bots und einem Opfer.



Aufgabe 4: Abwehr von DoS

a) Wie kann man Denial-of-Service Angriffe abwehren?

Erhöhen der Ressourcen

On-site Abwehrstrategien

- White/Blacklisting
- Login-Beschränkung, CAPTCHAs, Browser-Detection
- Sperren von Adressbereichen

Off-Site Maßnahmen

- Cloud-Umzug
- Caching, z.B. über CDN
- BGP-Routing anpassen

Aufgabe 4: Abwehr von DoS

b) Nennen und beschreiben Sie mögliche Probleme bei der Erkennung von DDoS-Angriffen auf Schicht 7 des OSI-Modells.

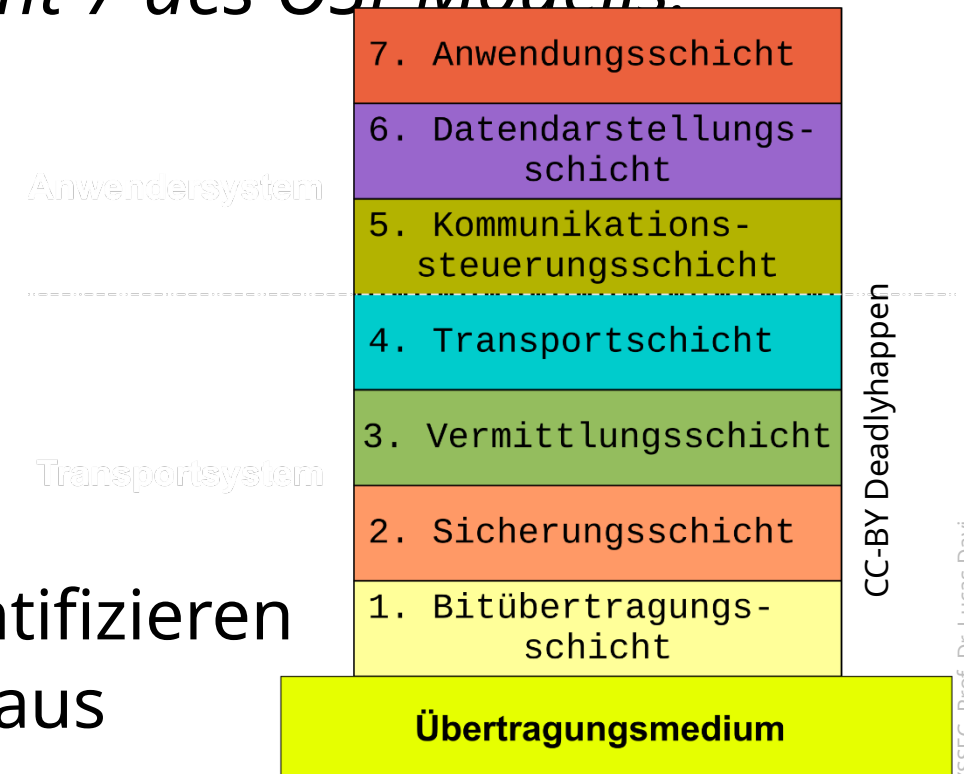
Schicht 7: Application Layer

Viele normale Requests

Packet Inspection teuer und komplex

Verschlüsselung, z.B. TLS

- Verschlüsselte Pakete schwer zu identifizieren
- Inspektion hebt Sicherheitsmodell aus



Aufgabe 4: Abwehr von DoS

c) Was ist das grundsätzliche Problem bei der Erhöhung der Kapazität von IT-Infrastruktur zur Abwehr von DoS-Angriffen?

Angriffe haben viele Ressourcen

Übersteigen i.d.R. die Möglichkeiten der Aufrüstung

Schlechter Kosten-Nutzen Effekt, da nur im Angriffsfall
gebraucht

Aufgabe 4: Abwehr von DoS

d) Beschreiben Sie den Unterschied zwischen On-Site und Off-Site Robustheitsmaßnahmen.

On-Site:

- Begrenzt durch eigene Ressourcen
 - Bandbreite
 - Serverkapazität
- Erhöhung begrenzt sinnvoll

Off-Site:

- Externe Dienstleister
- Offloading an CDN
- Filtern des Traffics vor dem eigenen Netz

Aufgabe 4: Abwehr von DoS

e) Was ist ein Content Delivery Network (CDN)? Wie kann man es zur Abwehr von DDoS-Angriffen einsetzen?

Netzwerk von Servern zur Bereitstellung von großen Datenmengen

Weit verteilt, gute Anbindung

Populär für Streaming-Dienste, Downloads, Bilder, populäre Bibliotheken

Abschirmung des eigenen Netzes durch Cloud-Dienst

- Caching
- Mitigation und Detection
- Scaling

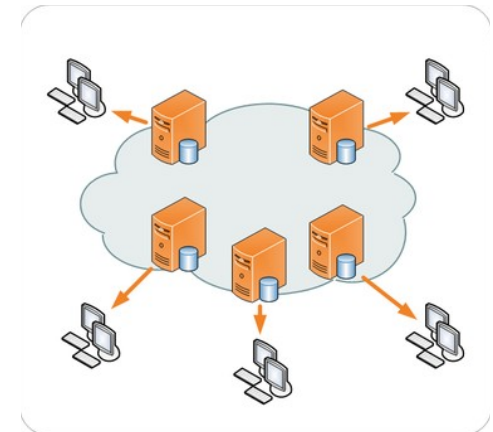
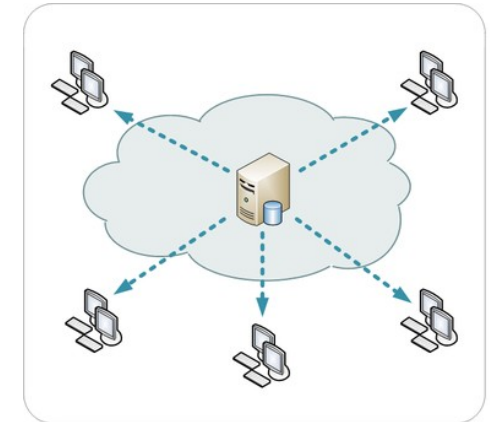
Aufgabe 4: Abwehr von DoS

f) Wie funktioniert DNS-basiertes Routing innerhalb eines CDNs?

Wie kann man stabil und einfach Last auf Server verteilen?

DNS: Namensauflösung nach IP-Adresse

- Kurze Gültigkeitsdauer
- Unterschiedliche IP-Adresse je nach Anfrage
-> gute Lastverteilung



Übung Cybersicherheit SoSe 2024

Vielen Dank für Ihre Aufmerksamkeit

Christian Niesler
Tristan Löding

Fakultät für Informatik
Arbeitsgruppe Systemsicherheit <https://www.syssec.wiwi.uni-due.de/>
Universität Duisburg-Essen